

Fingerprinting Web Server

Web server fingerprinting

- Web server fingerprinting is the task of identifying the type and version of web server that a target is running on.
- Accurately discovering the type of web server that an application runs on can enable security testers to determine if the application is vulnerable to attack.
 - For example, servers running older versions of software without up-to-date security patches can be susceptible to known version-specific exploits.
- The objective is to determine the version and type of a running web server to enable further discovery of any known vulnerabilities.

Techniques

- Techniques used for web server fingerprinting include banner grabbing, eliciting responses to malformed requests, and using automated tools to perform more robust scans that use a combination of tactics.
- They all strive to elicit some response from the web server which can then be compared to a database of known responses and behaviors, and thus matched to a known server type.

Banner Grabbing

- **Banner grabbing** is a technique used to gain information about a computer system on a network and the services running on its open ports.
- Administrators can use this to take inventory of the systems and services on their network.
- An intruder can use banner grabbing in order to find network hosts that are running versions of applications and operating systems with known exploits.

How Banner Grabbing Works

- Connection to the Server: The first step is establishing a connection to the server on a specific port. For web servers, this is typically port 80 (HTTP) or 443 (HTTPS).
- Sending a Request: A simple request is sent to the server. For HTTP servers, this might be a basic GET or HEAD request.
 - Analyzing the Response: The server's response often includes headers that reveal information about the server software. For example, an HTTP response might include a Server header that indicates the server software and its version.

- HTTP/1.1 200 OK
- Date: Thu, 05 Sep 2019 17:42:39 GMT
- Server: Apache/2.4.41 (Unix)
- Last-Modified: Thu, 05 Sep 2019 17:40:42 GMT
- ETag: "75-591d1d21b6167"
- Accept-Ranges: bytes
- Content-Length: 117
- Connection: close
- Content-Type: text/html
- ...

- HTTP/1.1 200 OK
- Server: nginx/1.17.3
- Date: Thu, 05 Sep 2019 17:50:24 GMT
- Content-Type: text/html
- Content-Length: 117
- Last-Modified: Thu, 05 Sep 2019 17:40:42 GMT
- Connection: close
- ETag: "5d71489a-75"
- Accept-Ranges: bytes

But what about this?

- HTTP/1.1 200 OK
 - Server: Website.com
 - Date: Thu, 05 Sep 2019 17:57:06 GMT
 - Content-Type: text/html; charset=utf-8
 - Status: 200 OK
- In cases where the server information is obscured, testers may guess the type of server based on the ordering of the header fields.

Sending Malformed Requests

- Web servers may be identified by examining their error responses, and in the cases where they have not been customized, their default error pages.
- One way to compel a server to present these is by sending intentionally incorrect or malformed requests.

- GET / SANTA CLAUS/1.1
- HTTP/1.1 400 Bad Request
- Date: Fri, 06 Sep 2019 19:21:01 GMT
- Server: Apache/2.4.41 (Unix)
- Content-Length: 226
- Connection: close
- Content-Type: text/html; charset=iso-8859-1
- <!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
- <html><head>
- <title>400 Bad Request</title>
- </head><body>
- <h1>Bad Request</h1>
- <p>Your browser sent a request that this server could not understand.

- </p>
- </body></html>

- GET / SANTA CLAUS/1.1
- <html>
- <head><title>404 Not Found</title></head>
- <body>
- <center><h1>404 Not Found</h1></center>
- <hr><center>nginx/1.17.3</center>
- </body>
- </html>

Using Automated Scanning Tools

- Automated tools can compare responses from web servers much faster than manual testing, and utilize large databases of known responses to attempt server identification. For these reasons, automated tools are more likely to produce accurate results.
 - [Netcraft](#), an online tool that scans sites for information, including web server details.
 - [Nikto](#), an Open Source command-line scanning tool.
 - [Nmap](#), an Open Source command-line tool that also has a GUI, [Zenmap](#).

Subdomain Enumeration

- Subdomain enumeration is a process of finding subdomains for one or more domains.
-

Passive sub-domain enumeration

- Certificate Transparency using crt.sh
- ASN Discovery
- Using Search Engines
- Using DNS aggregators (Github, Virustotal, etc)
- Subject alternate name (SAN)
- Using public datasets

ASN discovery

- **ASN discovery** is the process of identifying an organization's Autonomous System Number(s) and enumerating the IP ranges and network infrastructure associated with those ASNs for security assessment and reconnaissance.

Virtual hosting

DNS Record Analysis